

# Credential Exposure Threshold Spectra for Distributed Password Derivation

Yuanyi Zhang

*Independent Researcher*

---

## Abstract

Threshold sharing and distributed pseudorandom functions are commonly assessed by asking how many parties must be compromised before a master secret becomes available. For deterministic password derivation, this single threshold can miss a different failure: a compromised endpoint may keep the master secret hidden while using an over-broad evaluation interface to obtain many credential outputs. We define a finite capability-closure model that computes unrestricted derivation capability (UDC) and context-indexed credential exposure from the same compromise and approval state. Its quantitative output, the credential exposure threshold spectrum, gives the minimum number or monotone set cost of deployment domains needed to expose at least  $k$  unauthorized credential contexts under an approval budget  $q$ . We prove UDC dominance, show why a UDC-only analysis is incomplete below its threshold, establish monotonicity and UDC bounds for the spectrum, and derive an exact exposure formula for projection-bound authorization tickets. A reference analyzer accepts an arbitrary monotone compromise-set cost and produces minimal witnesses. We also instantiate a complete two-server scoped key-derivation path with RFC 9497 POPRF and signed tickets. Over 32 contexts, complete binding accepts one context, service/account-only binding accepts eight, and wildcard binding accepts all 32. Their thresholds are respectively two throughout; one for  $k \leq 7$  and two thereafter; and one for  $k \leq 31$  and two for  $k = 32$ . The local cryptographic path costs 1.15 ms median, excluding network and human approval delay. A temporal TLA+ model exhaustively checks ticket issue, expiry, revocation, replay, generation change, UDC dominance, and scope confinement, with a positive model and five fault controls. The contribution is a credential-specific analysis and metric, not a new sharing, PRF, token, or attack-graph primitive.

*Keywords:* password derivation, distributed pseudorandom function, threshold cryptography, authorization amplification, capability analysis, credential exposure

---

## 1. Introduction

Distributed trust is attractive for credential recovery and derivation. Shamir sharing makes a secret reconstructible only by a qualified set [1]; distributed pseudorandom functions (DPRFs) let qualified parties evaluate a keyed function without reconstructing the key [2]. Recent systems apply related techniques to password hardening, multi-factor key derivation, distributed key management, and secret recovery [3, 4, 5, 6, 7]. Their cryptographic access structure is only one part of the deployed security boundary. An endpoint may hold a share, a network-call credential, or authority to trigger honest infrastructure. The number of physical or administrative domains that an attacker must compromise can therefore be smaller than the nominal share threshold.

Even a correctly deployed DPRF creates a second question. Its security definition controls what is learned from a bounded set of legitimate evaluations; it does not decide which inputs the application should authorize. If one ticket intended for account  $c$  can be replayed for accounts  $c_1, \dots, c_n$ , the master key can remain unavailable while all corresponding passwords become computable. A binary question—“is unrestricted derivation authority available?”—does not represent this partial but operationally serious exposure. Root-Key recovery is one common way to obtain that authority, but it is not the only one.

Generic protection-system safety, attack graphs, capability safety, permission expansion, and least-privilege authorization already study closely related ideas [8, 9, 10, 11, 12, 13]. Consequently, fixed-point reachability, minimum-cost compromise, and context-bound tokens are not new contributions here. The research question is narrower:

How can a deterministic credential-derivation deployment jointly report (i) access to its UDC and (ii) the number of credential contexts made derivable by compromised domains and scoped approvals?

We answer with a dual-output closure and a credential exposure threshold spectrum (CETS). Rather than replace the UDC threshold, CETS resolves it

into a curve indexed by unauthorized output cardinality and approval budget. This immediately distinguishes a two-domain UDC threshold with exact per-context authorization from a deployment with the same UDC threshold but a one-domain path to most credential outputs.

The contributions are:

1. A finite semantics that derives UDC reachability  $M_R(X, T)$  and the context-indexed output set  $E_R(X, T)$  from one least fixed point over compromised deployment domains  $X$  and attacker-observed approvals  $T$ .
2. CETS, including cardinality and general monotone set-cost forms, UDC-dominance and UDC-only-incompleteness results, monotonicity, and a UDC-threshold bound.
3. An exact projection-exposure identity and closed-form approval-budget profile for tickets that bind only selected context fields.
4. A small executable analyzer, a complete two-server RFC 9497 POPRF scoped key-derivation reference protocol with signed tickets, 24 automated tests, local measurements, and a temporal TLA+ model with positive and negative controls.

The paper makes no new-primitive claim. It does not propose a new Shamir scheme, DPRF, OPRF, constrained PRF, capability token, or generic attack-graph algorithm. It also does not infer vulnerabilities in cited systems without a faithful protocol encoding.

## 2. Published foundations and novelty boundary

### 2.1. Access reachability and authority

Harrison, Ruzzo, and Ullman formalized the safety question of whether a subject can acquire a right [8]. MulVAL uses Datalog rules for multihost, multistage vulnerability analysis and produces attack explanations [9]. Attack-graph research also optimizes compromise or hardening cost [10]. These results establish both Horn-like reachability and cost-based analysis as prior art.

Object-capability research distinguishes possession of a reference from the authority reachable through program execution and formalizes authority safety [11]. PolyScope composes Android policies and system configuration to compute permission expansion and authorized attack operations [12]. Stateful

least-privilege authorization attenuates tokens using action history to limit misuse after theft [13]. Our use of “amplification” is therefore not a claim to a new general security principle. We specialize the output dimension to deterministic credentials and connect it to a Root-derived hierarchy.

### *2.2. Scoped and distributed pseudorandom evaluation*

Constrained PRFs allow a derived key to evaluate only inputs satisfying a constraint [14]. Macaroons attach contextual caveats to delegated authorization [15]. These works establish cryptographic input constraints and context-scoped capabilities; binding a ticket to a complete context is a repair pattern rather than our primitive.

Pythia provides a verifiable partially oblivious PRF service for password hardening and supports key rotation [3]. TOPPSS uses a threshold OPRF for password-protected secret sharing [4]. LaKey studies efficient lattice DPRFs for scalable distributed key derivation [6]. These publications preclude claims that remotely evaluated password-related PRFs, threshold OPRFs, hidden master keys, or DPRF-based key derivation are new here.

### *2.3. Recovery and deployment domains*

SafetyPin distributes encrypted-backup recovery across many HSMs and evaluates the cost of large-scale compromise [16]. MFKDF derives keys from multiple factors and supports threshold recovery [5]; later analysis demonstrates why state integrity and exact cryptographic specification matter [17]. SVR3 deploys secret recovery across heterogeneous enclaves and cloud providers [7]. Flock addresses how applications can deploy distinct trust domains on demand [18]. These systems motivate deployment-domain analysis, but their stated evaluation objectives are not an approval-budget-indexed spectrum of deterministic credential outputs.

Table 1 states the boundary without classifying any published system as insecure.

### *2.4. Why the object is not ordinary target-node counting*

An attack graph can encode each  $\text{Derived}(c)$  as a target node, and an existing graph engine can be used to compute the closure in this paper. CETS does not claim otherwise. Merely counting reachable target nodes, however, does not define the quantity studied here. Four additional structures are required. First, the state is indexed by an attacker-observed approval set  $T$  under an explicit budget  $q$ . Second, the security loss is the unauthorized

Table 1: Published foundations and the narrower question studied here.

| Published line                      | Established analysis object                                                 | Object added in this paper                                                   |
|-------------------------------------|-----------------------------------------------------------------------------|------------------------------------------------------------------------------|
| HRU; MulVAL;<br>attack graphs       | Right/capability reachability<br>and attack cost                            | Credential-output cardinality<br>under an approval budget                    |
| Capability<br>safety;<br>PolyScope  | Reachable authority,<br>permission expansion, attack<br>operations          | Joint UDC/output signature<br>for deterministic derivation                   |
| Constrained<br>PRFs;<br>Macaroons   | Cryptographic constraints<br>and contextual authorization                   | Exact diagnosis of collisions<br>in a concrete context<br>projection         |
| Pythia;<br>TOPPSS; LaKey            | Password-related PRF<br>services, threshold OPRF,<br>distributed derivation | Spectrum below and up to a<br>UDC threshold                                  |
| SafetyPin;<br>MFKDF; SVR3;<br>Flock | Recovery, factor composition,<br>and distributed trust<br>deployment        | Explicit composition of<br>deployment-domain and<br>callable-output exposure |

set  $E_R(X, T) \setminus T$ , rather than all reachable outputs; an approved password is not counted as its own authorization failure. Third, the distinguished UDC dominates every credential target and therefore supplies a global upper bound on the spectrum. Fourth, a verifier that checks a context projection induces equivalence classes whose sizes determine both single- and multi-ticket spill. These choices yield a two-parameter curve  $(k, q) \mapsto (\tau_E, \rho_E)$ , not a new reachability algorithm. A generic attack-graph or Datalog implementation can serve as the backend only after these credential-specific semantics and objectives have been supplied.

### 3. System and threat model

#### 3.1. Entities and contexts

Let  $D$  be a finite set of compromise domains. A domain is an operational failure boundary such as a managed endpoint, removable medium, approval service, network evaluator, administrative account, or colocated group of servers. Multiple machines controlled by one administrative principal may be one domain; machines do not become independent merely because they have different addresses.

Let  $C$  be a finite set of canonical credential contexts. A context can contain, for example,

$$c = (\text{serviceID}, \text{accountID}, \text{lineage}, \text{rootGeneration}, \text{policyID}).$$

Canonicalization is part of the model: field order, encoding, missing values, and version semantics must be unambiguous. We use a bounded  $C$  because the analyzer enumerates contexts; this represents a configured vault or a finite test universe, not all possible future identifiers.

Let  $K$  be a finite set of symbolic capabilities. Examples include raw shares, request tokens, approvals, partial evaluations,  $\text{Derived}(c)$ , and UDC. The distinguished *unrestricted derivation capability* UDC denotes authority sufficient to compute every  $\text{Derived}(c)$  for  $c \in C$  using the public derivation procedure. It is an authority abstraction, not necessarily a single materialized key. A reconstructed Root Key can imply UDC; in the reference POPRF case, UDC requires the endpoint-held input  $x$  together with either the approval-signing authority (while the evaluators remain honest online participants) or both evaluator keys. Accordingly, a well-formed rule set includes  $\{\text{UDC}\} \rightarrow \text{Derived}(c)$  for every  $c \in C$ . “Root capability” is used only when discussing the Root-Key instance of this more general object. Let  $R$  contain monotone rules whose consequences are automatically exercisable by the attacker after their premises are available. A human decision is not automatic unless the threat model explicitly places that decision under attacker control.

### 3.2. Attacker and approvals

The attacker compromises a set  $X \subseteq D$  and obtains the capabilities resident in those domains. The set  $T \subseteq C$  denotes legitimate approval tickets that the attacker can observe, steal, or invoke within the analyzed session. It does *not* mean all approvals issued elsewhere. A ticket may be modeled as an exact capability  $\text{Approval}(c)$  or by the fields that its verifier actually checks.

The attacker can exercise every automatic rule, choose derivation requests, and run the public derivation algorithm after obtaining UDC. In the reference POPRF experiment, the stable client input  $x$  is resident at the modeled endpoint and is available after endpoint compromise for every configured context; it is not a separate authorization domain. Cryptographic primitives are idealized: shares are not forged, MACs and signatures are not broken, and a reviewed DPRF reveals only outputs allowed by its application interface.

Availability attacks, social engineering, side channels, and compromise during legitimate plaintext use are outside the current model.

### 3.3. Security goals

The configured deployment has an intended minimum compromise-domain threshold  $t_{\text{cfg}}$ . Two distinct goals are checked:

1. *UDC-threshold preservation*: no  $X$  with  $|X| < t_{\text{cfg}}$  reaches UDC.
2. *authorized-context non-amplification*: for protected  $X$  and a bounded approval set  $T$ , derivable credential contexts remain within  $T$ .

An approved password can be visible to a compromised endpoint. The second goal only states that this approval does not become authority for additional credential contexts.

## 4. Joint capability semantics

**Definition 1** (Initial capability set).  $C_0(X, T)$  is the union of public capabilities, the capabilities stored in compromised domains  $X$ , and the modeled approval capabilities corresponding to attacker-observed tickets  $T$ .

**Definition 2** (Capability closure). For monotone rule set  $R$ , define

$$\text{Cl}_R(X, T) = \text{lfp}(S \mapsto C_0(X, T) \cup \text{consequences}_R(S)). \quad (1)$$

Because  $K$  is finite and rules only add capabilities, iteration from  $C_0(X, T)$  reaches the unique least fixed point in at most  $|K|$  additions.

**Definition 3** (Dual output). The UDC predicate and credential-exposure map are

$$M_R(X, T) = 1 \iff \text{UDC} \in \text{Cl}_R(X, T), \quad (2)$$

$$E_R(X, T) = \{c \in C : \text{Derived}(c) \in \text{Cl}_R(X, T)\}. \quad (3)$$

We call  $B_R(X, T) = (M_R(X, T), E_R(X, T))$  the dual-output signature.

Figure 1 summarizes the analysis. Both outputs come from one closure, preventing inconsistent assumptions between a UDC analysis and an interface analysis.

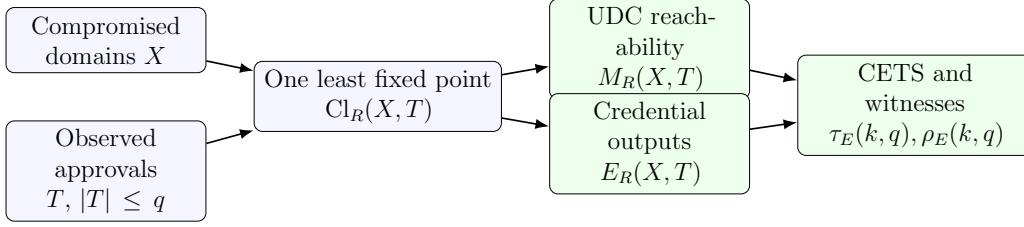


Figure 1: A single closure produces UDC reachability and context-indexed credential exposure; enumeration over  $X$  and  $T$  produces thresholds and witnesses.

**Theorem 1** (UDC dominance). *For a well-formed model as defined above,*

$$M_R(X, T) = 1 \implies E_R(X, T) = C.$$

*Proof.* If  $M_R(X, T) = 1$ , the closure contains UDC. For every  $c \in C$ , the well-formedness rule  $\{\text{UDC}\} \rightarrow \text{Derived}(c)$  therefore adds  $\text{Derived}(c)$  to the least fixed point. Thus every  $c$  belongs to  $E_R(X, T)$ ; the reverse inclusion follows from  $E_R(X, T) \subseteq C$ .  $\square$

The theorem rules out a four-independent-quadrant interpretation. UDC access without output exposure is not a reachable outcome. The meaningful distinction appears below the UDC threshold.

**Theorem 2** (UDC-only incompleteness below threshold). *For every finite  $C$  with  $|C| \geq 2$ , there exist rule sets  $R_1, R_2$  such that  $M_{R_1}(X, T) = M_{R_2}(X, T) = 0$  for all  $X, T$ , while  $E_{R_1}(X, T) \neq E_{R_2}(X, T)$  for some  $X, T$ .*

*Proof.* Let neither rule set contain a rule producing UDC. In  $R_1$ , an honest evaluator produces a partial evaluation only for the exact context carried by an observed ticket, giving  $E_{R_1}(X, T) = T$  whenever the endpoint interface is callable. In  $R_2$ , the same interface accepts any nonempty observed ticket for every context, giving  $E_{R_2}(X, T) = C$  whenever  $T \neq \emptyset$ . The UDC predicate is identically zero in both systems, but choosing a proper nonempty  $T \subset C$  separates the exposure maps.  $\square$

This theorem does not say the two coordinates are independent: by Theorem 1,  $M_R = 1$  forces maximal  $E_R$ . It says that the Boolean UDC result loses information precisely in the region where a DPRF is intended to protect the master.



## 5. Credential exposure threshold spectra

### 5.1. Non-amplification and spill

Let  $\mathcal{F} \subseteq \mathcal{P}(D)$  be the deployment compromise sets that the design intends to tolerate. For an approval budget  $q \geq 0$ , define

$$\text{ACNA}(\mathcal{F}, q) \iff \forall X \in \mathcal{F}, \forall T \subseteq C, |T| \leq q : E_R(X, T) \subseteq T. \quad (4)$$

For a particular state, unauthorized spill is

$$\text{spill}_R(X, T) = |E_R(X, T) \setminus T|.$$

The maximum spill for fixed  $X$  and budget  $q$  is

$$A_R(X, q) = \max_{T \subseteq C, |T| \leq q} |E_R(X, T) \setminus T|. \quad (5)$$

### 5.2. Cardinality and monotone set-cost spectra

Let  $\text{cost} : \mathcal{P}(D) \rightarrow \mathbb{R}_{\geq 0}$  be a compromise-set cost with  $\text{cost}(\emptyset) = 0$  and  $X \subseteq Y \Rightarrow \text{cost}(X) \leq \text{cost}(Y)$ . This admits correlated administration, shared tooling, economies of scale, or other coalition costs that cannot be expressed faithfully by independent per-domain weights. The usual additive model  $\text{cost}(X) = \sum_{d \in X} w_d$  is a special case.

**Definition 4** (Credential exposure threshold spectrum). *For target  $1 \leq k \leq |C|$  and approval budget  $q$ , define*

$$\tau_E(k, q) = \min\{|X| : \exists T \subseteq C, |T| \leq q, |E_R(X, T) \setminus T| \geq k\}, \quad (6)$$

$$\rho_E(k, q) = \min\{\text{cost}(X) : \exists T \subseteq C, |T| \leq q, |E_R(X, T) \setminus T| \geq k\}, \quad (7)$$

*An empty feasible set has value  $\infty$ .*

The two optimizations are independent. A single expensive domain may minimize  $\tau_E$ , while a larger coalition with a lower modeled set cost may minimize  $\rho_E$ . Reporting only the cost of the cardinality-minimal witness would not compute Eq. (7). Monotonicity of cost prevents adding compromised domains from making an attack cheaper, but additivity is not required.

**Proposition 1** (Spectrum monotonicity). *For fixed  $q$ ,  $\tau_E(k+1, q) \geq \tau_E(k, q)$  and  $\rho_E(k+1, q) \geq \rho_E(k, q)$ . For fixed  $k$ , both values are nonincreasing as  $q$  increases.*

*Proof.* A witness exposing at least  $k + 1$  unauthorized contexts also exposes at least  $k$ , so the feasible set for  $k + 1$  is contained in that for  $k$ . Conversely, the constraint  $|T| \leq q$  defines a subset of the feasible ticket sets for  $q + 1$ . Taking minima gives the stated inequalities.  $\square$

Define the ticket-free UDC threshold

$$\tau_M^0 = \min\{|X| : M_R(X, \emptyset) = 1\}$$

and its set-cost analogue  $\rho_M^0$ . Ticket-free is explicit because a recovery design might otherwise use approvals as premises for UDC release.

**Corollary 1** (UDC bound). *Under Theorem 1, for every  $q \geq 0$  and  $1 \leq k \leq |C|$ ,*

$$\tau_E(k, q) \leq \tau_M^0, \quad \rho_E(k, q) \leq \rho_M^0.$$

*Proof.* A minimum ticket-free UDC witness  $X$  is feasible for the spectrum because  $T = \emptyset$  satisfies every upper budget  $q$ . UDC dominance gives  $E_R(X, \emptyset) = C$ , so spill is  $|C|$ .  $\square$

The inequality can be strict. An over-broad evaluator may expose  $k < |C|$  outputs after one endpoint compromise even when two domains are required for UDC.

## 6. Projection-bound authorization

Many implementations do not express an arbitrary predicate over  $C$ ; they compare selected ticket fields. Let  $B$  be a subset of the canonical fields and let  $\pi_B(c)$  be their ordered projection. A ticket for  $c$  is accepted for  $c'$  exactly when  $\pi_B(c') = \pi_B(c)$ . This partitions  $C$  into equivalence classes

$$[c]_B = \{c' \in C : \pi_B(c') = \pi_B(c)\}.$$

**Theorem 3** (Projection-exposure identity). *Assume a compromised endpoint can request every context and compute its own partial evaluation, while an honest participant returns its partial exactly when the ticket projection matches. For a single ticket authorizing  $c$  and without UDC access,*

$$E_R(X, \{c\}) = [c]_B.$$

*Proof.* Every  $c' \in [c]_B$  passes the honest participant's only authorization predicate; the endpoint supplies the other partial, so  $\text{Derived}(c')$  is in the closure. Every  $c' \notin [c]_B$  fails that predicate, and by assumption no other rule produces the missing partial or UDC. Hence it cannot enter  $E_R$ .  $\square$

**Corollary 2** (Injectivity criterion). *In the profile of Theorem 3, exact one-context non-amplification holds for all  $c \in C$  iff  $\pi_B$  is injective on  $C$ .*

Injectivity over the current finite database is not a future-proof protocol condition. A deployable ticket should bind a collision-resistant digest of the complete canonical derivation context, the operation identifier, expiry, freshness generation, and protocol version. The digest must be computed from an unambiguous encoding.

**Theorem 4** (Exact approval-budget profile). *Let the projection partition have class sizes  $s_1 \geq s_2 \geq \dots \geq s_p$ . Under the assumptions of Theorem 3,*

$$A_R(X, q) = \sum_{i=1}^{\min(q, p)} (s_i - 1).$$

*Proof.* The first ticket in a class exposes its other  $s_i - 1$  members. A further ticket in that class cannot add an exposed context and moves one already exposed context into the approved set, so it cannot improve the objective. An optimum therefore selects at most one member per class and selects the largest class gains first.  $\square$

This closed form is specific to equality on a projection. General rule sets still require closure enumeration or a more scalable symbolic engine.

## 7. Reference analysis algorithm

The reference implementation intentionally supports a small two-layer subset of the semantics: unparameterized deployment-capability rules are followed by an exact, wildcard, or field-projection evaluator for context-indexed outputs. It uses exhaustive enumeration and is appropriate when the number of operational trust domains and the approval budget are small.

For every  $X \subseteq D$ , it computes the deployment closure by repeatedly applying enabled monotone rules. It then enumerates every  $T \subseteq C$  with  $|T| \leq q$ , applies the selected evaluator semantics, and records  $M_R(X, T)$ ,

$E_R(X, T)$ , spill, and a supplied  $\text{cost}(X)$ . The library API accepts any finite monotone set-cost oracle and validates monotonicity by enumeration; the command-line reference models use additive domain weights. For each  $k$ , it separately updates:

1. the lexicographically best cardinality witness  $(|X|, \text{cost}(X))$  for  $\tau_E(k, q)$ ; and
2. the lexicographically best set-cost witness  $(\text{cost}(X), |X|)$  for  $\rho_E(k, q)$ .

Minimal UDC witnesses are reduced by set inclusion. Exposure witnesses retain the compromised domains, approved context indexes, cause classification, and whether UDC was reachable.

**Proposition 2** (Reference-algorithm exactness). *For finite  $D, C, K$ , monotone deployment rules, a supported evaluator mode, and budget  $q$ , the exhaustive reference algorithm returns Eqs. (6)–(7) exactly for that encoded model.*

*Proof.* The algorithm enumerates every feasible  $X$  and  $T$ . Fixed-point iteration is sound because it adds only deployment-rule consequences and complete because it stops only when no enabled consequence remains. The selected evaluator then computes exactly the exposure set defined for its mode. Each feasible spill is therefore visited, and independent minima over all visited witnesses equal the defining minima.  $\square$

With  $d = |D|$  and  $n = |C|$ , the number of analyzed pairs is

$$2^d \sum_{i=0}^q \binom{n}{i}.$$

If closure evaluation costs  $L$ , the direct bound is  $O(d2^d + 2^d \sum_{i=0}^q \binom{n}{i}(L + n))$ , including monotonicity checks along every edge of the subset lattice for an externally supplied cost oracle. This is not proposed as a new generic attack-graph algorithm. Production-scale models can reuse symbolic or Datalog engines while preserving the same output definitions.

## 8. Evaluation

### 8.1. Research questions and method

The evaluation asks:

- RQ1** Does CETS distinguish deployments with the same UDC threshold but different callable-output exposure?
- RQ2** Does the projection identity predict exposure as context fields are bound?
- RQ3** Do the predicted exposure sets persist in a complete scoped credential-key derivation protocol rather than only a symbolic evaluator?
- RQ4** What is the local cost of the standalone projection analyzer and the complete reference scoped key-derivation path?
- RQ5** Does a temporal state model preserve scope across ticket issue, expiry, revocation, replay, and generation change?

The controlled context space is the Cartesian product of five binary fields: service, account, credential lineage, Root generation, and policy identity, giving 32 contexts. These configurations isolate semantics; they are not encodings of, or security claims about, the published systems in Section 2.

We model six deployment patterns around a nominal 2-of-3 recovery structure: automatic network release; independent approval; approval authority colocated with the endpoint; a release credential colocated with removable media; a 3-of-5 network layer entirely callable by one endpoint; and three network fragments plus approval in one administrative domain. Domain compromise costs are explicit test parameters, not empirical probabilities.

The analyzer tests ran with Python 3. The reference protocol was compiled in release mode with Rust 1.87 on macOS 26.5.2 and an Intel Core i9-9880H. Timing reports the median and nearest-rank P95. Projection-analyzer timing excludes network, storage, ticket issuance, and cryptographic evaluation; reference protocol timing is reported separately.

### 8.2. Deployment threshold results

Table 2 shows that only the independent-approval pattern preserves the configured two-domain threshold. Additional nodes do not help when one endpoint capability can automatically invoke enough of them; physical node count is not an access structure over compromise domains.

Table 2: Controlled deployment-pattern analysis.

| Pattern                                | Configured $t$ | Effective $t$ | Minimum witness characteristic                                      |
|----------------------------------------|----------------|---------------|---------------------------------------------------------------------|
| Automatic network release              | 2              | 1             | Endpoint calls honest release                                       |
| Independent approval                   | 2              | 2             | Two independently controlled domains                                |
| Approval authority at endpoint         | 2              | 1             | Endpoint owns request and approval                                  |
| Release credential on removable medium | 2              | 1             | Medium invokes network release                                      |
| 3-of-5 nodes callable by endpoint      | 2              | 1             | One token drives three node fragments                               |
| Shared administrative domain           | 2              | 1             | One administration boundary holds endpoint, approval, and fragments |

### 8.3. Spectra distinguish the missing failure

We combine two access patterns with exact and unscoped evaluation interfaces. The resulting analytical cases are:

1. independent approval, UDC threshold two, exact context binding;
2. the same UDC threshold, but one callable unscoped interface; and
3. a collapsed one-domain UDC threshold with exact ticket binding.

For a one-ticket budget, their cardinality spectra are respectively

$$[2, \dots, 2], \quad \underbrace{[1, \dots, 1]}_{31}, 2, \quad [1, \dots, 1].$$

The second case passes a UDC-only threshold check but one compromised endpoint exposes any target up to 31 unauthorized contexts. Exposing all 32 is different because one approved context is excluded from spill; the ticket-free UDC witness supplies the final spectrum point at threshold two. Figure 2 shows the curves.

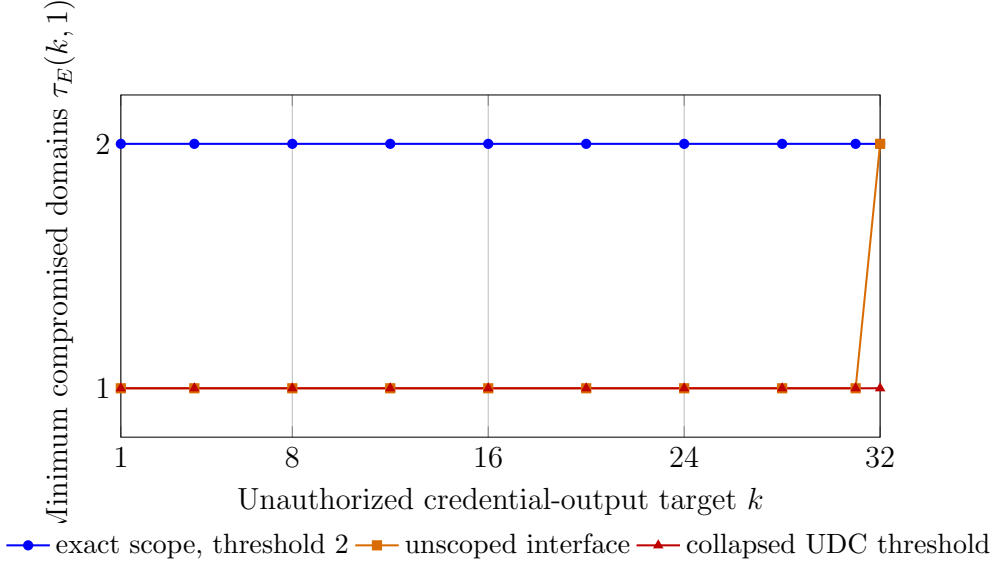


Figure 2: Credential exposure threshold spectra for three controlled configurations over 32 contexts and approval budget one.

The dual Boolean summaries are  $(0, 0)$ ,  $(0, 1)$ , and  $(1, 1)$  for, respectively, no collapse, scope amplification below the UDC threshold, and UDC-threshold collapse. The absent  $(1, 0)$  outcome agrees with Theorem 1.

#### 8.4. Context-binding curve

Table 3 binds fields cumulatively. Because each omitted binary field doubles a projection equivalence class, the measured exposure equals the closed form exactly. The unscoped interface and Root reconstruction (an instance of UDC) both expose 32 outputs, demonstrating that master non-materialization alone does not reduce worst-case callable-output exposure.

Approval budgets reveal structure that one ticket does not. Service-only binding creates two classes of size 16, so Eq. (5) gives maximum spill  $[15, 30, 30, 30]$  for budgets one through four. Full binding gives 32 singleton classes and  $[0, 0, 0, 0]$ .

#### 8.5. Cryptographic reference protocol

To test that the symbolic result survives a complete scoped credential-key derivation path, we built the two-server reference protocol in Figure 3. It uses the RFC 9497 POPRF mode with the ristretto255-SHA512 ciphersuite [19].

Table 3: Single-ticket exposure over the 32-context factorial space.

| Evaluator or bound fields   | Exposed contexts | Unauthorized spill |
|-----------------------------|------------------|--------------------|
| UDC via Root reconstruction | 32               | 31                 |
| Unscoped DPRF interface     | 32               | 31                 |
| Service                     | 16               | 15                 |
| Service, account            | 8                | 7                  |
| + lineage                   | 4                | 3                  |
| + Root generation           | 2                | 1                  |
| + policy identity           | 1                | 0                  |

Evaluators A and B hold independent POPRF keys. The client samples one stable 32-byte input  $x$  for the reference run and uses that same input for every configured context. In the threat model, a compromised endpoint obtains  $x$  and all candidate contexts;  $x$  is therefore not an additional authorization boundary. POPRF blinding treats it as private from either evaluator in the protocol transcript. With the complete canonical context supplied as POPRF public information, the client obtains and verifies

$$Y_A = \text{POPRF}_{k_A}(x; \text{Canon}(c)), \quad Y_B = \text{POPRF}_{k_B}(x; \text{Canon}(c)),$$

then computes

$$K_c = H(\text{cets-combined-v1} \parallel Y_A \parallel Y_B \parallel \text{Canon}(c)).$$

$K_c$  is a credential-specific secret consumed by a downstream deterministic password encoder; character-policy encoding is orthogonal to CETS and is not evaluated here. Both POPRF outputs are necessary. The minimum UDC witness in this deployment is compromise of the endpoint together with the approval authority: the former supplies  $x$  and arbitrary candidate contexts, while the latter can mint valid tickets that the two honest evaluators accept. A separate path compromises the endpoint and both evaluator domains. The first path has two domains, the second has three, and the evaluator pair alone lacks  $x$ . Consequently, the effective UDC threshold is two. This is a conjunctive composition of two published POPRF instances, not a claim to a new threshold-shared PRF.

For a configured binding-field set  $B$ , define

$$d_B(c) = H(\text{cets-ticket-binding-v1} \parallel \text{Canon}(\pi_B(c))).$$



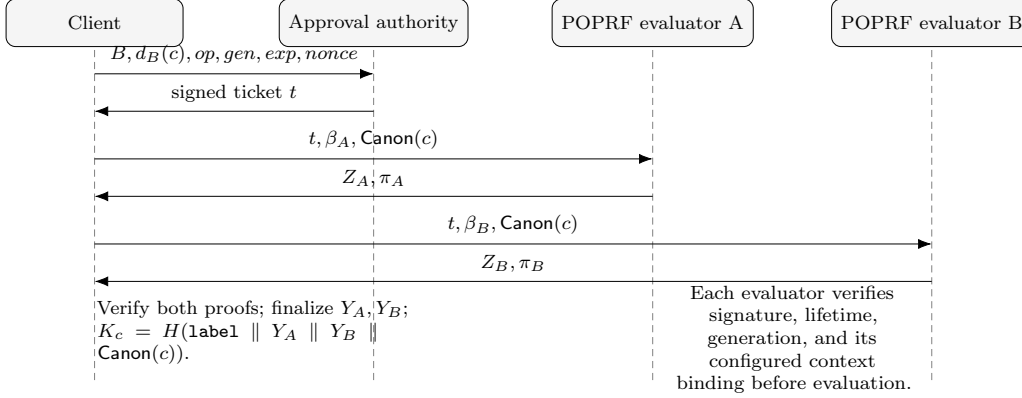


Figure 3: Complete two-server POPRF scoped credential-key derivation. The ticket-binding predicate is evaluated independently by both servers before the standardized cryptographic operation.

The exact configuration selects all five fields; the projected configuration selects only service and account; and the wildcard configuration sets  $B = \emptyset$ . An independent Ed25519 authority signs the protocol version, operation, the identifier of  $B$ ,  $d_B(c)$ , issue and expiry epochs, freshness generation, and nonce. Each evaluator verifies the signature, requires the signed  $B$  to equal its configured binding set, and checks the remaining state fields before evaluation. In all configurations, POPRF public information is the *complete* canonical context; only the application verifier is varied. The exact verifier compares a digest of all five fields, the projected verifier compares service and account only, and the wildcard negative control ignores context identity. The reference prototype intentionally reuses one still-live ticket to measure its accepted context set; it does not implement durable nonce-use or revocation storage. Section 8.7 analyzes those temporal controls separately.

Table 4 reports actual ticket verification, POPRF blind evaluation, proof verification, finalization, and output combination for every context. The accepted-set sizes equal the projection theorem: 1, 8, and 32. Repeated evaluation of one context was deterministic; all 32 context outputs were distinct in this finite sample; and a post-signature ticket mutation was rejected. These checks are functional evidence, not a collision-resistance estimate.

The threshold value two in Table 4 is induced by the minimum UDC witness  $\{\text{endpoint, approval authority}\}$ ; the two evaluator domains alone are not a witness.

Table 4: Two-server RFC 9497 POPRF reference protocol, one signed ticket and 32 candidate contexts.

| Ticket binding              | Accepted | Spill | CETS for $q = 1$                   |
|-----------------------------|----------|-------|------------------------------------|
| Complete five-field context | 1        | 0     | 2 for every $k$                    |
| Service and account only    | 8        | 7     | 1 for $k \leq 7$ ; 2 otherwise     |
| Wildcard negative control   | 32       | 31    | 1 for $k \leq 31$ ; 2 for $k = 32$ |

Table 5: Local projection-analysis latency over five runs.

| Contexts | Median (ms) | P95 (ms) |
|----------|-------------|----------|
| 32       | 1.40        | 1.55     |
| 1,024    | 34.82       | 36.88    |
| 10,000   | 335.01      | 340.12   |
| 100,000  | 3,555.38    | 3,863.90 |

Across 1,000 complete exact-scope credential-key derivations, local latency was 1.151 ms median and 1.456 ms P95. This includes two POPRF proof flows and ticket verification, but excludes network round trips, approval delay, and durable replay storage. It is a cryptographic baseline rather than a production-service latency claim.

#### 8.6. Local analysis cost

Table 5 reports the standalone projection analyzer. The observed scaling is approximately linear for a fixed field projection, as expected from one pass that constructs projection classes. The 100,000-context median is 3.56 s. This is an offline analysis-tool measurement, not credential derivation latency.

#### 8.7. Tests and temporal model checking

Twenty Python tests cover closure witnesses, deployment thresholds, projection classes, approval-budget profiles, the three reachable dual outcomes, cardinality spectra, independent set-cost minimization, and rejection of a non-monotone cost oracle. Four Rust tests cover canonical encoding, the three ticket-scope cardinalities, output determinism and context separation, and signature/lifetime enforcement.

The TLA+ model [20] has two credential contexts, time values 0..2, and two freshness generations. Its state records ticket issue, expiry, revocation, use count, derivation requests, partial evaluations, an abstract UDC flag, and

exposed outputs. Evaluators check exact scope, ticket lifetime, revocation state, freshness generation, and single use. The model also permits UDC acquisition and checks that it immediately exposes all contexts. This action abstracts deployment-specific witnesses; in the reference interpretation it represents either endpoint-plus-approval compromise or the endpoint-plus-both-evaluators path, never the evaluator pair alone.

With every control enabled, TLC exhaustively generated 3,997 states and 888 distinct states, reached graph depth 10, and left no states on the queue. The type, UDC-dominance, below-UDC scope, expiry, revocation, generation, and replay invariants all held. Five single-fault configurations provide negative controls. A projected-context verifier reaches the expected cross-context exposure trace; disabling expiry, revocation, generation, or single-use checks reaches the corresponding expired-ticket, revoked-ticket, stale-generation, or replay acceptance trace. Thus each asserted temporal control is exercised by a concrete counterexample when removed. We do not compare generated-state counts for fault models because parallel TLC may discover the same counterexample after different amounts of frontier work.

These finite exhaustive checks validate the final abstract transition relation and its control dependencies. They do not verify the POPRF library, hardware isolation, durable storage, network liveness, or unbounded time.

## 9. Security interpretation and repair

### 9.1. *Two necessary controls*

The results imply that threshold preservation and exact evaluation scoping are both necessary for compartmentalization:

1. Deployment shares, request credentials, approval keys, and network participants must be assigned to actual compromise domains. An honest service that automatically releases a qualifying capability to a compromised endpoint can collapse the effective threshold without being compromised.
2. Every partial evaluator must validate the complete canonical derivation context and the intended operation. A secure DPRF with an unscoped application interface can preserve its master-key theorem while exposing legitimate outputs on attacker-chosen inputs.

These controls are conjunctive. Exact tickets do not repair UDC compromise; additional shares do not repair an over-broad evaluation oracle.

### 9.2. Binding construction boundary

A practical approval can use the domain-separated projection digest  $d_B(c)$  defined in Section 8.5 and sign or MAC an unambiguous encoding of

$$\begin{aligned} &\text{protocolVersion} \parallel \text{operation} \parallel B \parallel d_B(c) \parallel \\ &\text{freshness} \parallel \text{expiry} \parallel \text{nonce}. \end{aligned}$$

For a production non-amplifying interface,  $B$  contains the complete canonical derivation context; proper subsets are the analyzed projection cases. Collision resistance, signature or MAC unforgeability, replay control, and canonical encoding are required. Existing contextual capabilities and constrained PRFs provide construction options [15, 14]. CETS decides whether the resulting interface amplifies the modeled approvals; it does not replace the underlying security proof.

### 9.3. Conditional composition statement

Suppose a reviewed DPRF is secure for the chosen corruption model under adaptive queries; fewer than its threshold parties reveal no master key; ticket verification is unforgeable and binds the complete canonical context; the protocol satisfies  $\text{ACNA}(\mathcal{F}, q)$ ; and no other closure rule releases a raw share or UDC. Then, for  $X \in \mathcal{F}$  and  $c^* \notin T$ , the application provides no authorized evaluation path for  $c^*$ . The adversary's remaining ability to distinguish or compute the fresh output reduces to the selected DPRF advantage, ticket-forgery probability, and context-digest collision probability.

This is a composition boundary, not a new DPRF theorem. Its purpose is to make the authorization premise explicit rather than silently importing it into a master-key security claim.

## 10. Limitations and validity

*Finite monotone semantics.* The spectrum analyzer does not natively represent revocation, time, rate limits, probabilities, concurrency, or non-monotone state. A short-lived ticket is modeled only as present or absent in one analysis epoch. The separate temporal model covers bounded issue, expiry, revocation, replay, and generation transitions, but not unbounded executions or probabilistic events.

*Model fidelity.* Results are only as sound as domain boundaries, automatic-rule classification, and context canonicalization. Administrative correlation can invalidate a claimed independent domain. Conversely, placing all legitimate approvals in  $T$  would overstate attacker authority. Independent model review is required for claims about a concrete system.

*Evidence scope.* The deployment configurations are controlled models designed to exercise the definitions. The POPRF case is an executable scoped key-derivation reference protocol, but it is not an independently reviewed encoding of a published end-to-end system or a production deployment. Analyzer timing and local cryptographic timing exclude network, storage, and human approval delay and should not be read as end-to-end service performance.

*Cryptographic boundary.* The reference case invokes a published POPRF implementation and verifies its proofs; it neither proves that library nor implements a threshold-shared single PRF key. Its conjunctive two-key composition is a case-study mechanism, not a new primitive. Adaptive multi-server corruption, availability under a malicious evaluator, side channels, durable replay-state failure, and key erasure require separate treatment. A fully compromised endpoint during a legitimate password-use session can observe that password.

*Novelty boundary.* The phrase CETS names the metric defined here; it is not evidence of worldwide priority. Fixed-point reachability, minimum-cost attack analysis, authority safety, permission expansion, scoped authorization, and DPRFs are established work. The defensible contribution is their credential-specific joint output, UDC relation, and approval-budget-indexed exposure curve.

## 11. Conclusion

A UDC threshold answers when a deterministic credential hierarchy is wholly compromised, but not how many legitimate outputs can be obtained through a callable interface before that threshold is reached. The proposed semantics computes both facts from one capability closure. UDC dominance removes an invalid independent-failure state; UDC-only incompleteness shows why the remaining below-threshold region needs a set-valued output analysis. CETS then turns that set into cardinality and cost curves indexed by the

approval budget. The cost coordinate permits any monotone compromise-set cost, retaining additive weights only as a convenient reference instance.

For projection-bound tickets, exposure is exactly an equivalence class and the multi-ticket spill has a closed form. In the executable POPRF case, complete, service/account, and wildcard binding accept 1, 8, and 32 of 32 candidate contexts, producing exactly the predicted spectra. The temporal model further shows that scope must be combined with expiry, revocation, replay, and generation checks. The resulting design test is concise: protect both the UDC and the authority to request each credential output throughout the ticket lifecycle.

## Appendix A. Reproducibility boundary

The accompanying artifact contains:

- JSON models for six deployment patterns, seven context-binding patterns, and three joint cases;
- a standard-library Python closure and spectrum analyzer;
- a Rust two-server RFC 9497 POPRF reference protocol, dependency lockfile, signed-ticket checks, and generated JSON results;
- generated JSON witnesses and local scaling results;
- 20 Python tests and 4 Rust tests; and
- the temporal TLA+ model and six configurations summarized in Section 8.7.

The artifact is intended to reproduce the finite claims in this paper. It is not a production credential service, cryptographic library, or certification of any cited published system.

## References

- [1] A. Shamir, How to share a secret, *Communications of the ACM* 22 (11) (1979) 612–613. doi:10.1145/359168.359176.
- [2] M. Naor, B. Pinkas, O. Reingold, Distributed pseudo-random functions and KDCs, in: *Advances in Cryptology—EUROCRYPT 1999*, Vol. 1592 of *Lecture Notes in Computer Science*, Springer, 1999, pp. 327–346. doi:10.1007/3-540-48910-X\_23.

- [3] A. Everspaugh, R. Chaterjee, S. Scott, A. Juels, T. Ristenpart, The pythia PRF service, in: 24th USENIX Security Symposium, USENIX Association, 2015, pp. 547–562.  
URL <https://www.usenix.org/conference/usenixsecurity15/technical-sessions/presentation/everspaugh>
- [4] S. Jarecki, A. Kiayias, H. Krawczyk, J. Xu, TOPPSS: Cost-minimal password-protected secret sharing based on threshold OPRF, in: Applied Cryptography and Network Security, Vol. 10355 of Lecture Notes in Computer Science, Springer, 2017, pp. 39–58. doi:10.1007/978-3-319-61204-1\_3.
- [5] V. Nair, D. Song, Multi-factor key derivation function (MFKDF) for fast, flexible, secure, and practical key management, in: 32nd USENIX Security Symposium, USENIX Association, 2023, pp. 2097–2114.  
URL <https://www.usenix.org/conference/usenixsecurity23/presentation/nair-mfkdf>
- [6] M. Geihs, H. Montgomery, LaKey: Efficient lattice-based distributed PRFs enable scalable distributed key management, in: 33rd USENIX Security Symposium, USENIX Association, 2024, pp. 4319–4335.  
URL <https://www.usenix.org/conference/usenixsecurity24/presentation/geihs>
- [7] G. Connell, V. Fang, R. Schmidt, E. Dauterman, R. A. Popa, Secret key recovery in a global-scale end-to-end encryption system, in: 18th USENIX Symposium on Operating Systems Design and Implementation, USENIX Association, 2024, pp. 703–719.  
URL <https://www.usenix.org/conference/osdi24/presentation/connell>
- [8] M. A. Harrison, W. L. Ruzzo, J. D. Ullman, Protection in operating systems, Communications of the ACM 19 (8) (1976) 461–471. doi:10.1145/360303.360333.
- [9] X. Ou, S. Govindavajhala, A. W. Appel, MulVAL: A logic-based network security analyzer, in: 14th USENIX Security Symposium, USENIX Association, 2005.  
URL <https://www.usenix.org/conference/14th-usenix-security-symposium/mulval-logic-based-network-security-analyzer>

- [10] L. Wang, S. Noel, S. Jajodia, Minimum-cost network hardening using attack graphs, *Computer Communications* 29 (18) (2006) 3812–3824. doi:10.1016/j.comcom.2006.06.018.
- [11] S. Maffei, J. C. Mitchell, A. Taly, Object capabilities and isolation of untrusted web applications, in: *IEEE Symposium on Security and Privacy*, IEEE, 2010, pp. 125–140. doi:10.1109/SP.2010.16.
- [12] Y.-T. Lee, W. Enck, H. Chen, H. Vijayakumar, N. Li, Z. Qian, D. Wang, G. Petracca, T. Jaeger, PolyScope: Multi-policy access control analysis to compute authorized attack operations in android systems, in: *30th USENIX Security Symposium*, USENIX Association, 2021, pp. 2579–2596.  
URL <https://www.usenix.org/conference/usenixsecurity21/presentation/lee-yu-tsung>
- [13] L. Cao, L. Meng, D. Stefan, E. Fernandes, Stateful least privilege authorization for the cloud, in: *33rd USENIX Security Symposium*, USENIX Association, 2024, pp. 3477–3494.  
URL <https://www.usenix.org/conference/usenixsecurity24/presentation/cao-leo>
- [14] D. Boneh, B. Waters, Constrained pseudorandom functions and their applications, in: *Advances in Cryptology—ASIACRYPT 2013*, Vol. 8270 of *Lecture Notes in Computer Science*, Springer, 2013, pp. 280–300. doi:10.1007/978-3-642-42033-7\_15.
- [15] A. Birgisson, J. G. Politz, Ú. Erlingsson, A. Taly, M. Vrabie, M. Lentzner, Macaroons: Cookies with contextual caveats for decentralized authorization in the cloud, in: *Network and Distributed System Security Symposium*, Internet Society, 2014. doi:10.14722/ndss.2014.23212.
- [16] E. Dauterman, H. Corrigan-Gibbs, D. Mazières, SafetyPin: Encrypted backups with human-memorable secrets, in: *14th USENIX Symposium on Operating Systems Design and Implementation*, USENIX Association, 2020, pp. 1121–1137.  
URL <https://www.usenix.org/conference/osdi20/presentation/dauterman>



- [17] M. Scarlata, M. Backendal, M. Haller, MFKDF: Multiple factors knocked down flat, in: 33rd USENIX Security Symposium, USENIX Association, 2024, pp. 4301–4318.  
URL <https://www.usenix.org/conference/usenixsecurity24/presentation/scarlata>
- [18] D. Kaviani, S. Tan, P. G. Kannan, R. A. Popa, Flock: A framework for deploying on-demand distributed trust, in: 18th USENIX Symposium on Operating Systems Design and Implementation, USENIX Association, 2024, pp. 721–743.  
URL <https://www.usenix.org/conference/osdi24/presentation/kaviani>
- [19] A. Davidson, A. Faz-Hernandez, N. Sullivan, C. A. Wood, Oblivious pseudorandom functions (OPRFs) using prime-order groups, Tech. Rep. RFC 9497, RFC Editor (2023). doi:10.17487/RFC9497.  
URL <https://www.rfc-editor.org/rfc/rfc9497.html>
- [20] L. Lamport, Specifying Systems: The TLA+ Language and Tools for Hardware and Software Engineers, Addison-Wesley, 2002.